



Game of Cones

Why Your Crisis Plan Shouldn't Melt Under Pressure

Technical tabletops, crisis exercises, and other ways to suffer on purpose

Richard Suls | Blue Team Con 2026

Your incident response playbook is sitting on a server.

The server just got encrypted.

Now what?

REVERSESEC



Who here has a driver's license?



REVERSE

Richard Suls

Technical Identity

[Querying whois.suls.net]

IP: 10.42.0.23

ham radio callsign: KB1BKI

CC: US

Registry: arin

Signal: suls.01

email: Richard@Suls.net

Suls@reversesec.com

LI: richardsuls

- US Lead, Security Advisory Consulting at Reversesec
- 20+ years across financial services, healthcare, critical infrastructure, and government
- Court-qualified expert witness in state and federal courts since 2007: 100+ matters, from homicide cases to cloud intrusions
- Crisis management exercise design and delivery for major financial institutions, critical infrastructure operators, museums, and national monetary authorities (to name a few).





Understanding the Exercises - Overview

Crisis Management Exercise (CME)

- Designed for senior leadership and key decision-makers, not the technical team
- Injects: stakeholder communications, regulatory compliance, reputation management, ransom pay/no-pay
- Validates executive decision-making, policy clarity, and external communications under pressure

Technical Tabletop Exercise (TTX)

- Built for incident responders, engineers, and select leaders
- Deep, system-specific scenarios: malware analysis, containment, forensic timelines, recovery
- Tests detection, containment, eradication, and restoration in your actual environment

Both: Identify gaps. Strengthen coordination. Build confidence.

Crisis Management Exercises: A Closer Look

Who's in the Room

C-suite, General Counsel, Communications/PR, Board representatives, Regulatory liaisons. Not the SOC. Not the IR team. The people making business decisions under legal and reputational pressure.

What They're Deciding

Do we pay the ransom? Who contacts regulators, and when? What do we tell customers, employees, the press? What does our cyber insurance policy require before we act?

What It Surfaces

Who actually has decision authority, and who thinks they do. Communication breakdowns between legal, PR, and technical teams. Regulatory readiness gaps. Policies that have never been tested under pressure.

Technical Tabletop Exercises: A Closer Look

Who's in the Room

Incident responders, SOC analysts, engineers, IT leadership, select security leaders.

What They're Working Through

Detection → Containment → Eradication → Recovery. Tool-specific decisions, log analysis, forensic timelines, system restoration.

What It Surfaces

Single points of failure, the one person who knows the forensic tool. Playbooks that reference decommissioned systems. Escalation paths that dead-end at people who left the company. Coordination gaps between shifts, teams, and disciplines.

The Timing is Critical

1 Worst Time to Test

During an actual crisis. Nobody learns to drive mid-crash.

2 Proactive Exercises

Identify weaknesses when the organization is calm and has time to fix them

3 Not a "Nice-to-Have"

Table stakes, and now regulation: NYDFS 500.16(d) and DORA Art. 11 require annual testing; NIS2 Art. 21 mandates crisis management.

What Is an Inject?

"A structured piece of new information, delivered during an exercise, designed to force a decision."

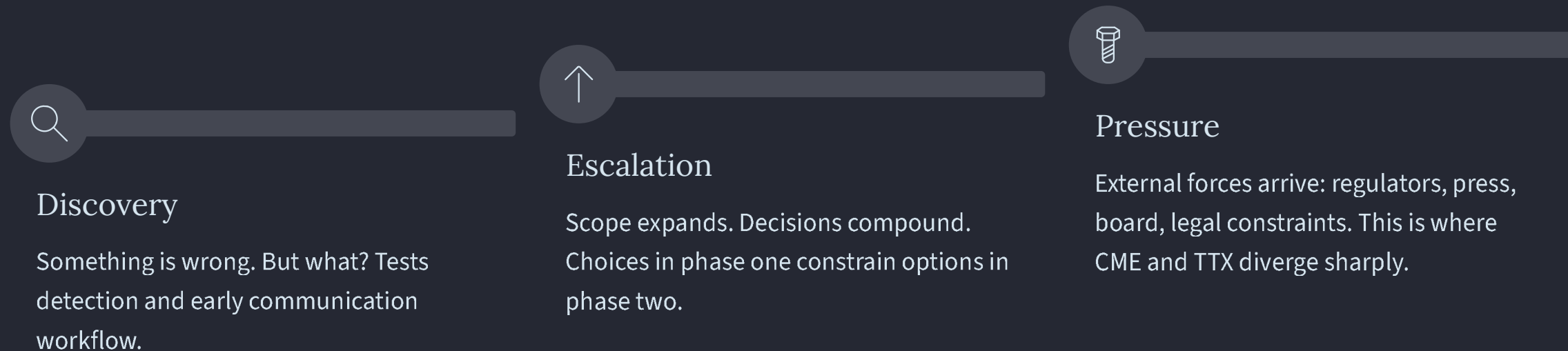
Good Injects Are:

- Realistic: grounded in your actual threat landscape
- Ambiguous: no obvious right answer
- Escalating: each one raises the stakes
- Timed: delivered to build pressure, not just inform

Bad Injects Are:

- Too obvious: telegraphed answers eliminate the pressure
- Too easy: validate comfort instead of exposing gaps
- Disconnected: scenarios that couldn't realistically happen to this organization

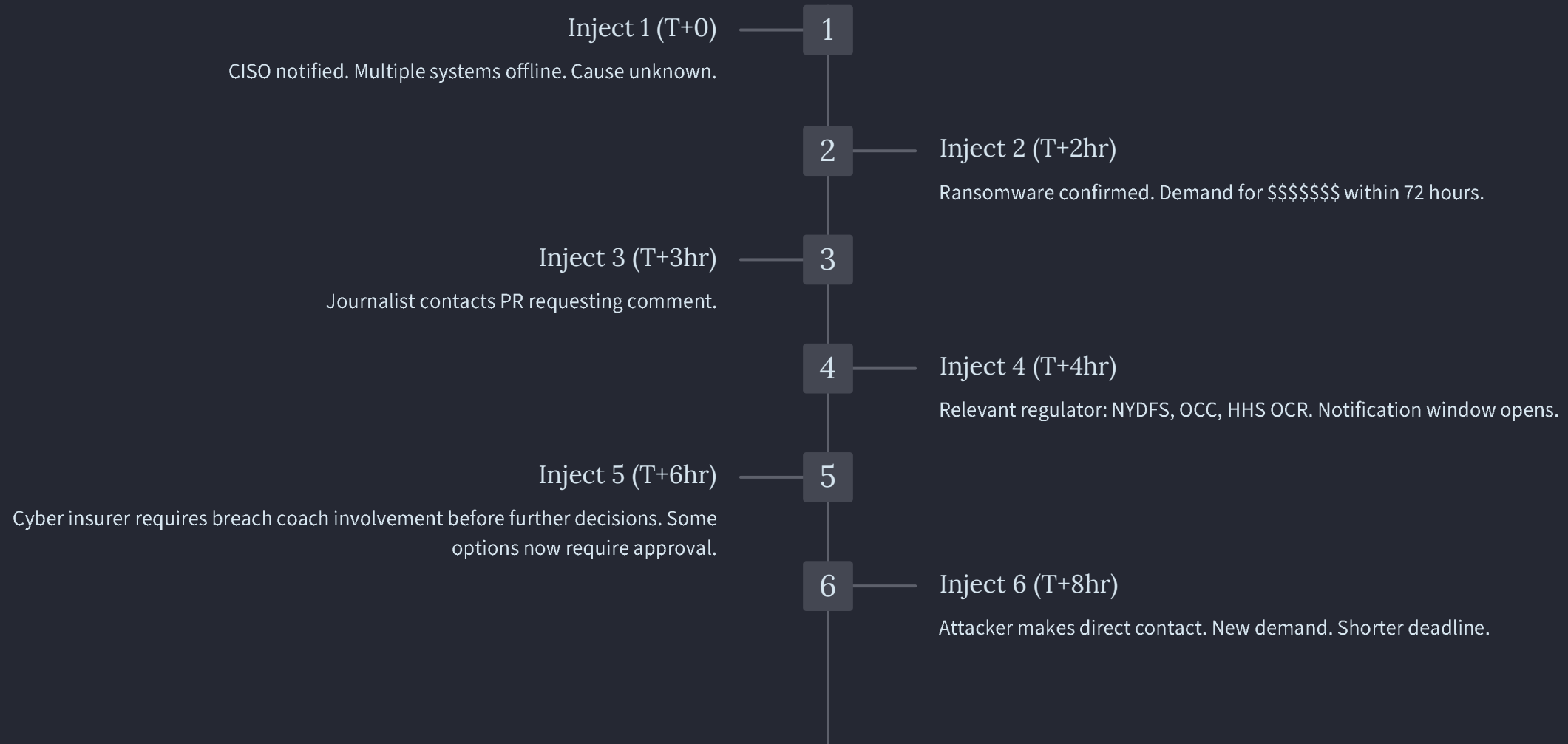
Designing an Inject Sequence



Design Principles

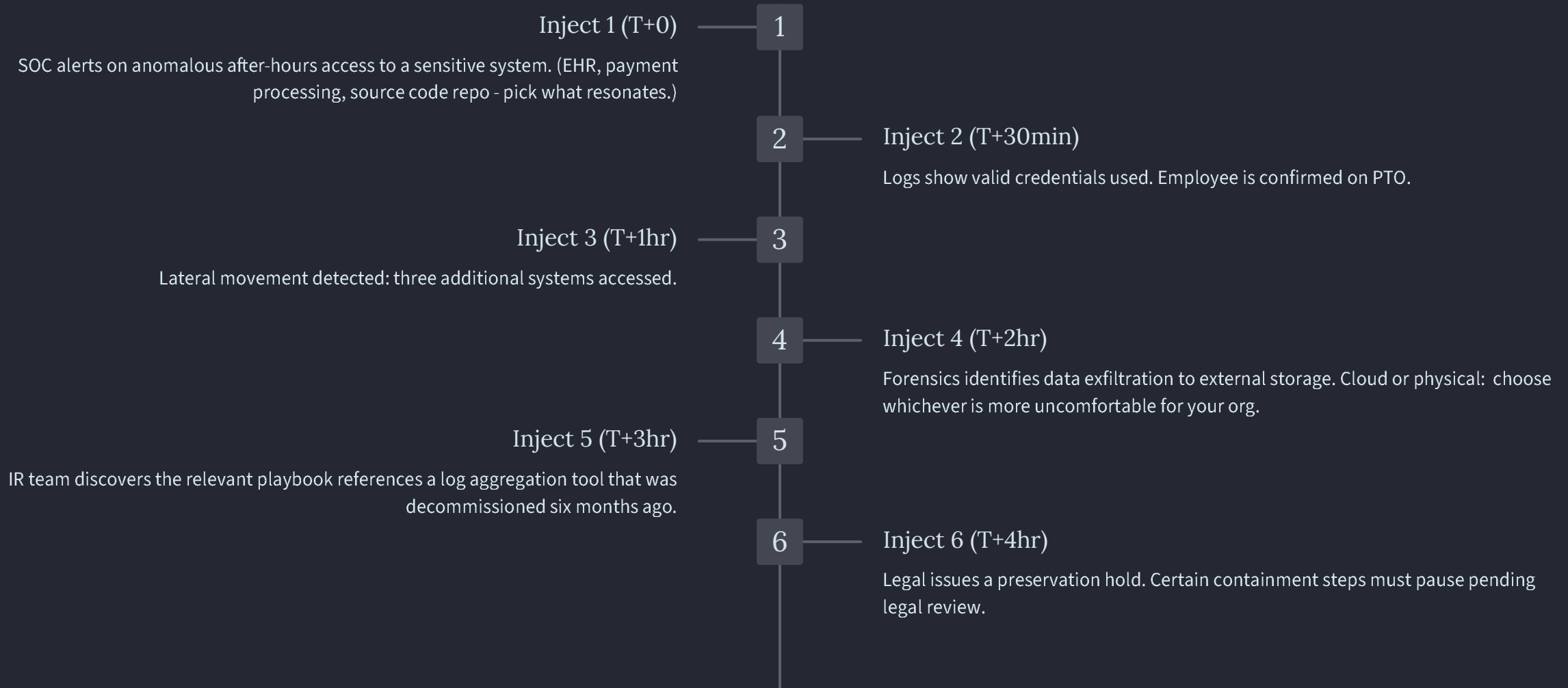
- Map injects to your actual threat landscape
- Every inject requires a decision, not just an observation
- Build in at least one inject targeting a known weakness
- Layer in external stakeholder pressure for CME tracks

Sample Inject Sequence - Crisis Management Exercise



REVERSE

Sample Inject Sequence - Technical Tabletop Exercise



What We See, Over and Over

Failure Pattern 1: The Unread Playbook

It's on a server. The server is encrypted. Nobody printed it.

Failure Pattern 2: The Missing Person

The escalation path leads to someone who changed roles, changed companies, or left last quarter.

Failure Pattern 3: The First 45 Minutes

Leadership spends them figuring out who owns the response. Instead of executing one.

The plan doesn't survive contact with reality. The team does, if they've practiced.

Best Practices for Impactful Crisis Exercises

Clear Objectives
Know what you're testing before you start

Regular Scheduling
Once is not a program



Realistic Scenarios

Threats that could actually happen to your organization

Debrief and Learn

Post-exercise review is not optional



Beyond Process: The Human Dimension



Testing Ground

Safe simulation. Real pressure. No operational consequences.



Gap Analysis

Surfaces process and communication failures before incidents make them expensive.



Team Empowerment

Trust is built in rehearsal. Not during the performance.

Trust Is Not Soft. It's Structural.

Evidence

You've seen how your colleagues perform under real pressure

Predictability

You know who stays calm, who communicates clearly, who improvises well, and who doesn't

Legitimacy

The organization knows who to rely on, and why

Predictability under pressure is the closest thing to control you will have.

Who Thrives? Who Freezes? Who Fills the Gap?

The Calm One

Often not the most senior person in the room. The exercise identifies them, and gives them legitimacy.

The Bottleneck

Every decision flows through one person. That person is overwhelmed. That's a structural risk, not an asset.

The Communicator

Translates technical reality into leadership language in real time. Invaluable. Usually underrecognized.

The Gap-Filler

Spots what nobody else is covering and moves without being told. Exactly who you want.

Aligning Leadership and Technical Teams



The Exercise Ends. The Work Starts.

The Hot Debrief (immediately after: 10 to 30 minutes)

- Capture raw reactions while the scenario is still present
- What felt wrong? Where did you feel stuck? What surprised you?
- Don't over-structure this. Let people talk.

The Cold Debrief (1 to 2 weeks later)

- Organized findings and recommendations from the facilitator
- Action items with owners and deadlines
- Gap analysis becomes a remediation roadmap

What Not To Do:

- Turn it into a blame session
- Turn it into a victory lap

ABF: Always Be Fixing

Change is easier to accept in small doses. Make small fixes consistently. Don't wait for the next major program review.

Every Exercise Generates:

- Playbook updates
- Role and decision-right clarifications
- Tool or process improvements
- The scenario for the next exercise

The Goal: A Living Program, Not a One-Time Event.

Schedule the next exercise before the debrief closes.

Cybersecurity and the Well-Rehearsed Playbook

Cyber Threats

Specialized challenges that require purpose-built response programs, not generic crisis frameworks

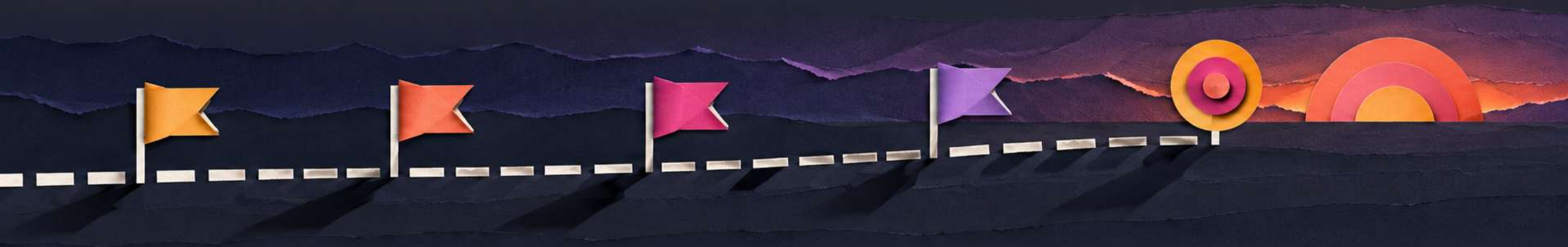
Playbook Essentials

Roles, responsibilities, protocols. Printed. Accessible. Current.

Continuous Adaptation

Threats evolve. Your playbook must evolve with them.

"If it's on your server and your server is encrypted, it's wallpaper."



Key Takeaways

- 1 Test Before Crisis**
Don't discover your gaps at the worst possible moment
- 2 Address Gaps Early**
Exercises are cheaper than incidents. Every time.
- 3 Align Your Teams**
Leadership and technical teams must share a situation picture, not just a chain of command
- 4 Debrief and Iterate**
A good debrief is how exercises become improvements instead of shelf-ware
- 5 Build the Culture**
Crisis readiness is not a project. It's a practice.



Closing Thoughts

Final Message

The calmest person in the room on the worst day of the organization's life didn't get there by accident. They practiced.

The Ice Cream Analogy

A crisis plan that's never been tested melts under the first real heat. Game of Cones. Don't find out the hard way.

Thank You

Now: who's got a story?

Contact Information



Email

Suls@Reversesec.com



Website

Reversesec.com

They practiced. So should you.

REVERSESEC



Q&A: Your Turn

Not just questions, stories.

If you've lived through a crisis, or run an exercise that went sideways:
I want to hear it.



Open Floor

Questions and discussion welcome



Share Experiences

What have you seen? What broke in
a real incident that an exercise might
have caught?

